

Day 22 – Q22 - ASP.NET Core Controller-Based Web API – Insurance Domain MCQs

1. An Insurance Management API has Admin, Agent, and Customer users. Which ASP.NET Core mechanism is primarily responsible for determining whether an authenticated user can access the PolicyController?

- A. Authentication
- B. Authorization
- C. Serialization
- D. Model Binding

Answer: B.

2. In an Insurance API, a customer successfully logs in and receives a JWT. What does successful authentication primarily establish?

- A. The customer can access every API
- B. The customer's identity has been verified
- C. The customer's role has been changed
- D. The customer's insurance policy is automatically approved

Answer: B.

3. An Insurance API has the following controller:

[Authorize]

[ApiController]

[Route("api/[controller]")]

public class PolicyController : ControllerBase

{

}

What does [Authorize] primarily require?

- A. A valid database connection
- B. A valid JWT or other configured authentication credential
- C. Admin role only
- D. HTTPS certificate

Answer: B.

4. An insurance company's ClaimsController should only be accessible to users having the Admin role. Which attribute is most appropriate?

- A. [AllowAnonymous]
- B. [Authorize]
- C. [Authorize(Roles = "Admin")]
- D. [HttpAdmin]

Answer: C.

5. The Insurance API exposes a registration endpoint:

```
[HttpPost("register")]
```

The endpoint must be accessible to users who are not logged in. Which attribute should typically be used?

- A. [Authorize]
- B. [AllowAnonymous]
- C. [RequireAuthentication]
- D. [AnonymousOnly]

Answer: B.

6. An insurance agent is authenticated, but attempts to access an admin-only policy configuration endpoint. What HTTP status code is normally appropriate?

- A. 200
- B. 401
- C. 403
- D. 500

Answer: C.

7. An insurance customer sends a request without a valid authentication token to a protected endpoint. What status code normally indicates that authentication is required?

- A. 400
- B. 401
- C. 403
- D. 404

Answer: B.

8. What is the key distinction between 401 Unauthorized and 403 Forbidden in an Insurance API?

- A. 401 means invalid input; 403 means server error
- B. 401 means authentication is missing/invalid; 403 means authenticated but not permitted
- C. 401 means database failure; 403 means validation failure
- D. They are interchangeable

Answer: B.

9. An insurance company wants to allow users to access policy information only when they have a Policy.Read permission claim. Which approach is most appropriate?

- A. Role-based authorization only
- B. Policy-based authorization
- C. Model validation
- D. Exception filtering

Answer: B.

10. Consider:

```
[Authorize(Policy = "CanApproveClaim")]
```

```
[HttpPost("approve")]
```

```
public IActionResult ApproveClaim(int claimId)
{
    ...
}
```

What is the purpose of CanApproveClaim?

- A. JWT encryption
- B. Database connection configuration
- C. Authorization policy
- D. Exception policy

Answer: C.

11. An Insurance API uses JWT authentication. Which information is commonly stored in JWT claims?

- A. User identity and roles
- B. SQL Server table indexes
- C. Complete insurance policy documents
- D. Application source code

Answer: A.

12. Which component in ASP.NET Core is responsible for validating incoming JWT bearer tokens?

- A. AddControllers()
- B. JWT Bearer authentication handler
- C. Entity Framework Core
- D. Serilog

Answer: B.

13. An Insurance API receives this request:

Authorization: Bearer eyJhbGciOiJIUzI1Ni...

What does Bearer indicate?

- A. The token is a refresh token
- B. The client is sending a bearer authentication credential
- C. The request is encrypted using AES
- D. The user has Admin privileges

Answer: B.

14. Which JWT component generally contains claims such as sub, role, and user ID?

- A. Header
- B. Payload
- C. Signature
- D. Encryption key

Answer: B.

15. An Insurance API wants to prevent a JWT issued for one application from being accepted by another application. Which JWT validation setting is particularly relevant?

- A. Audience
- B. Password
- C. ConnectionString
- D. Serilog

Answer: A.

16. A JWT issued by the company's Identity Server should only be trusted if it was issued by the expected authority. Which JWT property helps validate this?

- A. Issuer
- B. Route
- C. Controller
- D. Database

Answer: A.

17. Why should an Insurance API validate the JWT signature?

- A. To determine the customer's insurance premium
- B. To ensure the token has not been tampered with and is from a trusted issuer
- C. To improve SQL query performance
- D. To serialize the response

Answer: B.

18. An access token for an Insurance API expires after 15 minutes. What is the primary purpose of token expiration?

- A. To increase database size
- B. To limit the lifetime of a compromised access token
- C. To disable logging
- D. To remove user roles

Answer: B.

19. An insurance portal uses short-lived access tokens and long-lived refresh tokens. What is the primary purpose of a refresh token?

- A. To access SQL Server directly
- B. To obtain a new access token without requiring the user to log in again
- C. To bypass authorization
- D. To replace HTTPS

Answer: B.

20. Where should a server-side application ideally store a JWT signing secret?

- A. Hard-coded in the controller
- B. In source code comments
- C. Secure configuration/secret management
- D. Inside a customer's insurance policy

Answer: C.

21. An authenticated customer requests:

GET /api/policies/10025

The API should ensure policy 10025 actually belongs to that customer. What type of security check is required?

- A. Authentication only
- B. Resource-level authorization
- C. JSON serialization
- D. Logging only

Answer: B.

22. An Insurance API wants to log when a claim is submitted. Which built-in abstraction should application code normally depend upon?

- A. Console.WriteLine()
- B. ILogger<T>
- C. FileStream
- D. Debug.Write()

Answer: B.

23. An Insurance API needs to correlate logs from one request across multiple services. Which value is particularly useful?

- A. Correlation/trace ID
- B. Password
- C. JWT signing key
- D. Database password

Answer: A.

24. What is a major advantage of Serilog over simple text-based logging?

- A. Structured logging
- B. Automatic JWT generation
- C. Automatic database migrations
- D. Automatic authorization

Answer: A. Structured logging

25. A global exception handler catches an unexpected exception while processing an insurance claim. What should it ideally do?

- A. Return the entire exception stack trace
- B. Log the exception and return a safe standardized error response
- C. Ignore the exception
- D. Return HTTP 200

Answer: B.